Day22_BrokenAccessControl

PART A — FUNDAMENTALS

1. What is authentication: Process of verifiying identity of user or system.

2. What is authorization: Process of determining what an authenticated user is allowed to access.

3. Explain the difference between authentication and authorization.
Authentication: who are you?
Authorization: what are you allowed to do?

4. What is access control: It is a security mechanism managing and restricting who can access specific resource and perform certain action on it.

5. What is Broken Access Control: It is a security vulnerability that occurs when application failed to enforce access permissions, allowing every user to access data they are not authorized to do so.

6. What does Least Privilege mean: It means giving user the only permission required to perform their tasks, reducing risk of unauthorized access.

7. What does Deny by Default mean: It means the access is denied unless the permission is granted explicitly.

8. Why is authentication alone not enough to protect sensitive functionality?
Authentication only verify user identity, it does not determine what the user is allowed to do if have credentials user can access sensitve information or do impersonation.

PART B — ACCESS CONTROL TYPES

9. Explain vertical access control: access based on user's role or permission level.

10. Give one fictional example of a vertical access control problem.
Student logging in university portal and can access admin dashboard allowing to modify other students data without permission.

11. Explain horizontal access control: It ensures users with same level of privilege can only access their own data or resources.

12. Give one fictional example of a horizontal access control problem.
Student 1 changes URL for student ID and views Student 2 personal informations.

13. What is context-dependent access control: Access allowed based on current situation or access including time, location and so on…

14. Give one simple fictional example.
Online shopping system allowing customer to cancel the order while status being pending.

Day22_BrokenAccessControl

PART C — OBJECT AUTHORIZATION

15. What is an object/resource identifier: It is a unique identifier to identify a specific resource in a system.

16. Explain the IDOR concept in your own words: IDOR [Insecure Direct Object Reference] it is a security vulnerability that occurs when an application allows user to access another user's resources and make them modify without proper permission.

17. Why does knowing a record ID not automatically mean a user is allowed to access it?
It is a particular resource. It does not prove the user owns the resource permission to access it. Application must verify user's authorization

18. Why must ownership/permission be checked on the server?
Server-side checks ensure that users cannot bypass security restrictions by modifying URLs, requests, or client-side code. The server must verify that the authenticated user has permission to access or modify the requested resource.

PART D — SERVER-SIDE SECURITY

19. Why is hiding an Admin button in the browser not enough security?
Hiding an Admin button only prevents users from seeing it on the interface. Users may still access the admin functionality by manually changing the URL or sending requests directly to the server. Therefore, proper server-side authorization is required.

20. Explain why authorization checks should be performed in trusted server-side logic.
Authorization checks should be performed on the server because users can modify or bypass client-side code. The server must independently verify the user's identity, role, and permissions before allowing access to sensitive data or functionality.

PART E — ACCESS CONTROL MATRIX

Create an access control matrix for this fictional internship portal.

RESOURCES	Student	Reviewer	Admin
Lessons	Allow	Allow	Allow
Own Submission	Allow	Allow only when authorized	Allow
Other Student Submission	Deny	Allow only when authorized	Allow
Review Panel	Deny	Allow only when authorized	Allow
User Management	Deny	Allow only when authorized	Allow

Day22_BrokenAccessControl

PART F — CASE STUDY

Fictional scenario:

Student A is logged into an internship portal.

Student A requests Student B's private assignment submission.

The server finds Student B's submission and returns it without checking ownership or permission.

Answer:

1. Is Student A authenticated: YES

2. Is Student A necessarily authorized to view Student B's submission: NO

3. Which security check is missing: server-side ownership and authorization checks.

4. Is this primarily a vertical or horizontal access control issue: Horizontal access control

5. Which OWASP Top 10:2025 category applies: A:01: 2025

6. What is the possible impact?
   - Exposure of private student information.
   - Unauthorized access to another student's assignment.

7. Give a high-level defensive recommendation.
Implement proper server-side authorization checks. Before returning a submission, the server must verify that the authenticated user owns the submission or has been explicitly granted permission to access it.